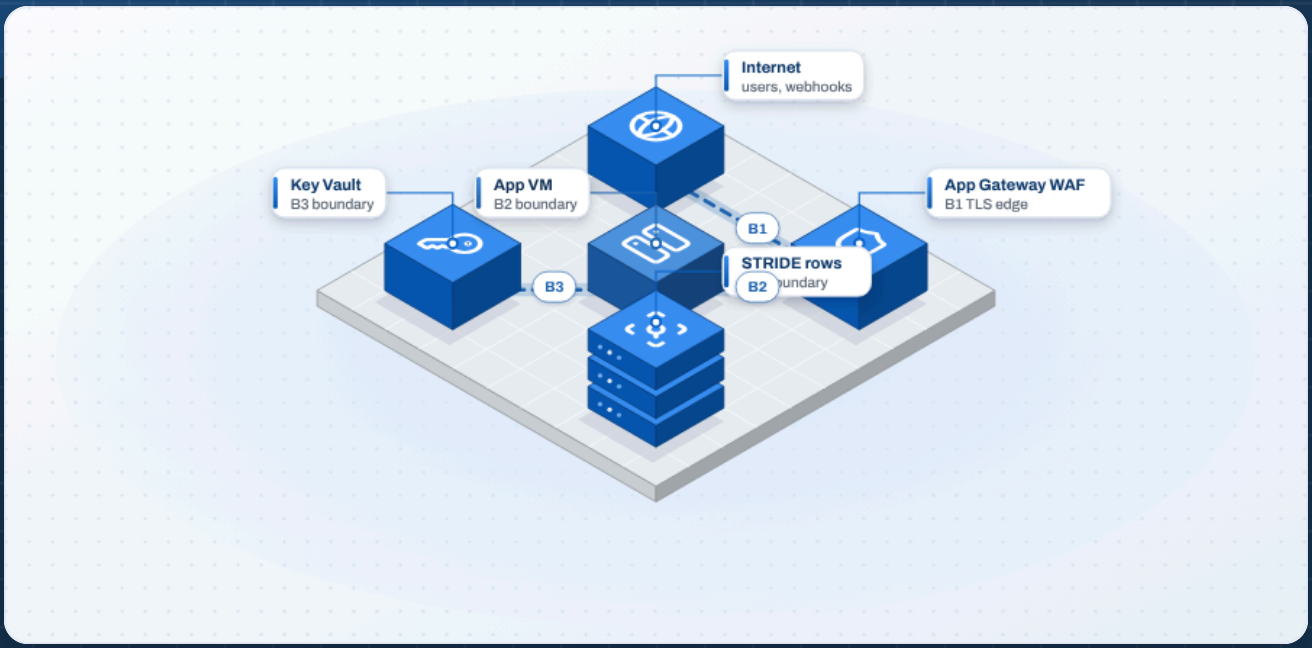
STANDARD OPERATING PROCEDURE · FIELD GUIDE SERIES

SOP-AZ-103

Threat Modeling an Azure Build with STRIDE

Trust boundaries, data flows and attack surface of the deployed environment, reviewed at every boundary with STRIDE from the infrastructure and identity layer, without reading application code.

Security Architecture | STRIDE | Risk



DOCUMENT ID	SOP-AZ-103
VERSION	1.1
EFFECTIVE	October 2026
AUDIENCE	Security architects, independent reviewers, client approvers
AUTHOR	Richmond Dieujuste, Principal Consultant

Contents

1. Concepts You Need First 2

1.1 Trust boundaries in a stamp 2

1.2 STRIDE in one table 3

2. Access, Prerequisites and Planning 4

2.1 Level of access required 4

2.2 Prerequisites checklist 4

3. Procedure in the Azure Portal 5

4. Template · Inventory and Threat Rows 8

5. Verification and Troubleshooting 9

5.1 Verify the model 9

5.2 Troubleshooting 9

6. Summary, Glossary and Review 10

6.1 Chapter summary 10

6.2 Glossary 10

6.3 Framework references 10

LEARNING OBJECTIVES

After working through this procedure you will be able to:

- Identify the trust boundaries of a deployed Azure environment from the tenant itself.
- Run STRIDE per boundary and write one threat row per real threat with its control and evidence.
- Rate each row with the risk matrix and take the model to client sign-off.

CHAPTER 1

Concepts You Need First

A threat model answers four questions: what are we protecting, where can it be attacked, what could go wrong, and what stops it. For an infrastructure review the answers come from what is deployed (networks, identities, vaults, gateways) rather than from source code, so the review stays inside an infrastructure-only scope.

KEY CONCEPT · CHECK EVERY DOOR, NOT EVERY ROOM

A building inspector does not open every drawer. They walk the doors between areas with different owners: street to lobby, lobby to office, office to vault. A **trust boundary** is one of those doors, and STRIDE is the checklist read at each one.

1.1 Trust boundaries in a stamp

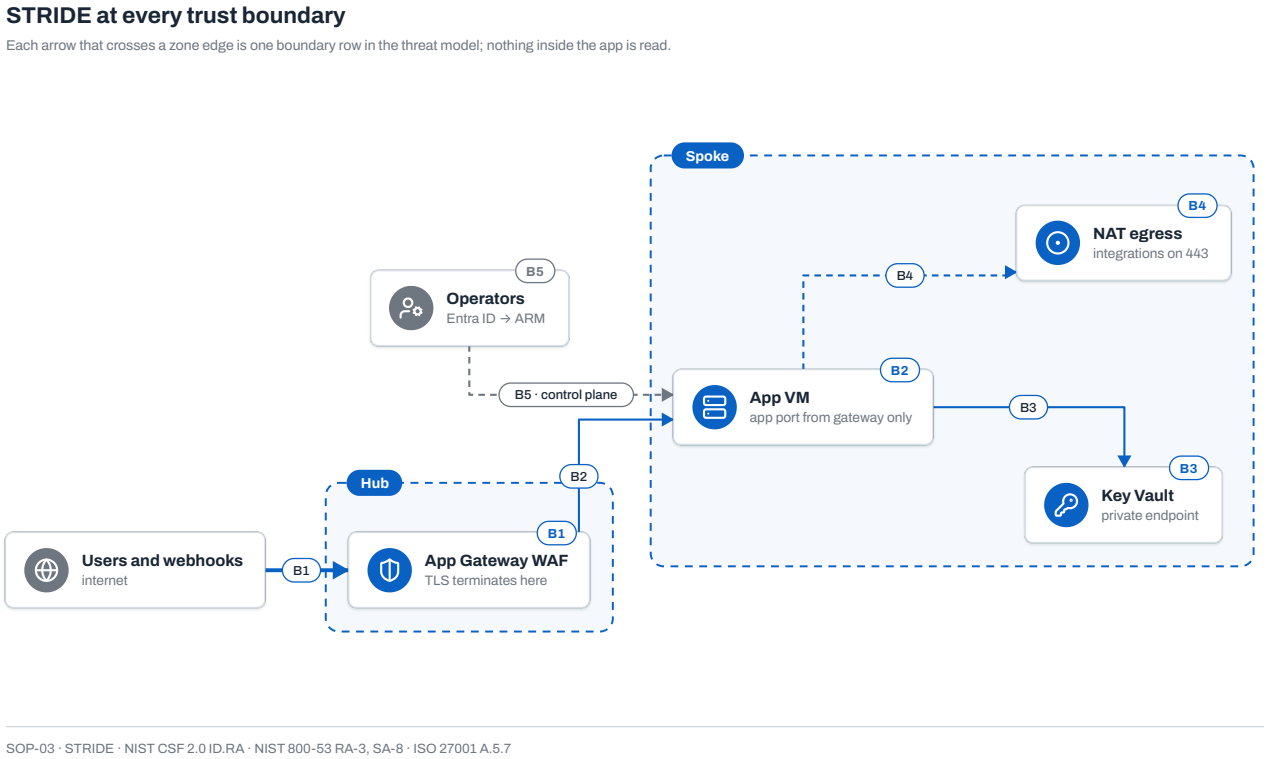


Figure 1. Each arrow that crosses a zone edge is one boundary row in the threat model.

ID	Boundary	What crosses it
B1	Internet to gateway	User and webhook HTTPS
B2	Gateway to app VM	HTTP on the app port
B3	App VM to Key Vault	Secret reads over the private endpoint

ID	Boundary	What crosses it
B4	App VM to internet egress	Calls to integrations on 443
B5	Operator to control plane	Role, policy and resource writes
B6	Backup to paired region	Recovery points

1.2 STRIDE in one table

Letter	Threat	Question at the boundary
S	Spoofing	Can someone pretend to be a trusted caller?
T	Tampering	Can data be changed in transit or at rest?
R	Repudiation	Could someone deny doing it, for lack of a log?
I	Information disclosure	Can data reach someone who should not see it?
D	Denial of service	Can the service be overwhelmed or cut off?
E	Elevation of privilege	Can a low role become a high one?

CHAPTER 2

Access, Prerequisites and Planning

2.1 Level of access required

Task	Role	Notes
Read the environment	Reader at the product root	No write access is needed for any step
Network topology	Reader plus Network Watcher in the region	Network Watcher is enabled per region
Approve the model	Client approver	A named person with authority to accept risk

WHY IT MATTERS · INDEPENDENCE

The reviewer should not be the person who built the environment. The builder attends the workshop to answer design questions but does not rate their own work.

2.2 Prerequisites checklist

- [ ] Design document and data flow diagrams from the build.
- [ ] Risk rating matrix agreed (likelihood 1 to 3, impact 1 to 3).
- [ ] Workshop booked with the builder, reviewer and a client representative.
- [ ] Out-of-scope items written down (for example payment processor, application code).

CHAPTER 3

Procedure in the Azure Portal

NOTE · HOW THESE SCREENS WERE CAPTURED

Screens in this chapter were captured read-only from a live engagement tenant. Client, product and people names, tenant, subscription and object IDs, email addresses and public IPs are replaced (`org`, `app`, `Contoso`, `00000000-…`, `203.0.113.10`). Compliance figures and unrelated rows are blurred. Portal labels move over time; the setting names are what matter.

STEP 1 Inventory the environment

1. Run `SOP-03-architecture-inventory.ps1` with Reader access. It changes nothing.
2. It writes networks, peerings, NSG rules, public IPs, private endpoints and each managed identity's roles to one JSON file.
3. Record the printed SHA-256 hash in the workshop notes.

STEP 2 See how the resources connect

1. Open the stamp resource group › **Resource visualizer**.
2. Confirm which resources talk to which: VM to NIC to subnet, private endpoints to vault and storage, disk set to vault.
3. For the network view open **Network Watcher › Topology**.

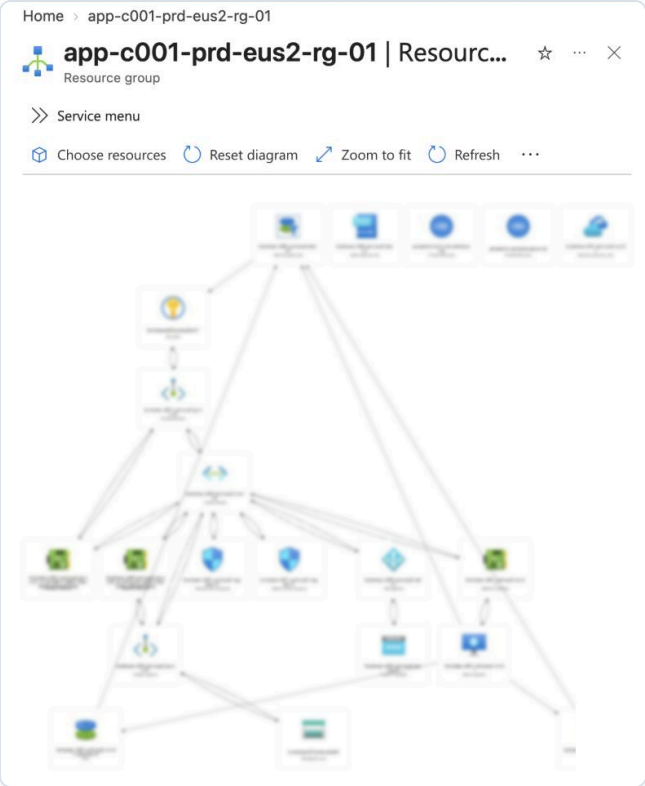


Figure 2. Resource visualizer for the stamp resource group. Labels softened; the shape of the dependencies is what the workshop needs.

STEP 3 Mark the trust boundaries

1. List every place data crosses from one zone of control to another (the B1 to B6 table in Chapter 1 is the starting set).
2. Open each spoke **Virtual network › Peerings** to confirm which networks can reach which.

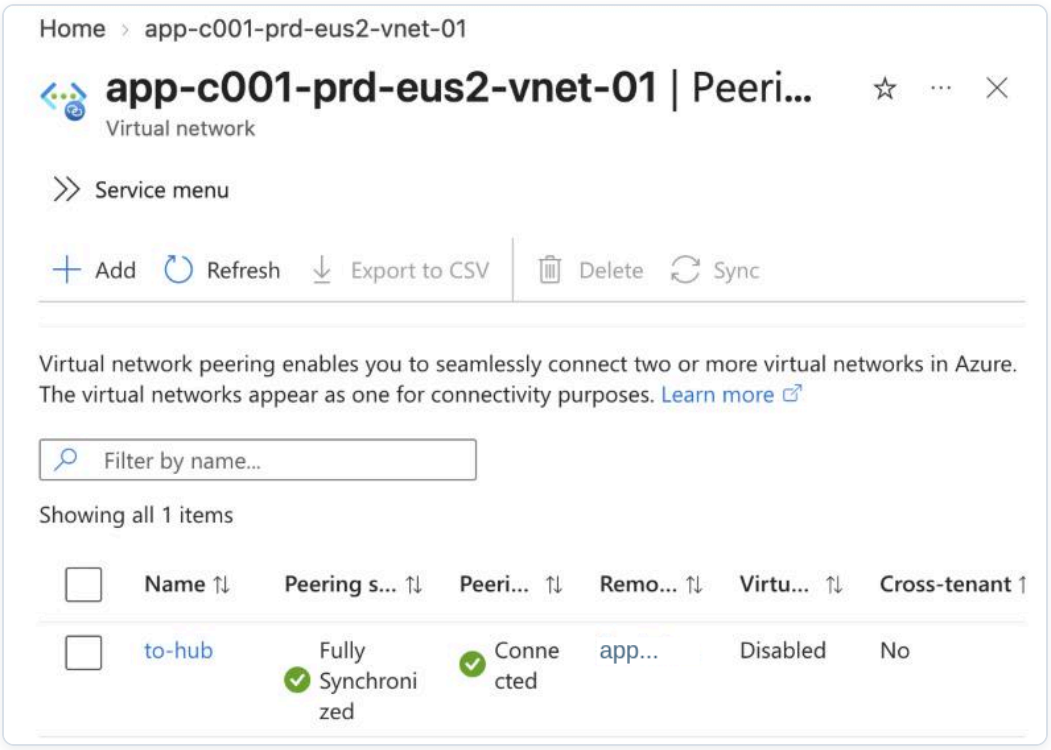


Figure 3. The spoke peers only with the hub. No spoke-to-spoke path exists, so customer stamps cannot reach each other.

STEP 4 Run STRIDE per boundary

1. For every boundary ask the six STRIDE questions.
2. Write one row per real threat in `SOP-03-threat-model.template.csv`, with the existing control and the evidence file that proves it.
3. A threat with no control is a gap; leave the control column empty rather than guessing.

> **CAUTION · REPORT EXPOSURE WITHIN ONE BUSINESS DAY**
> If the review finds data already at risk (for example an open inbound rule to a data port), report it to the client within one business day; do not wait for the final report.

STEP 5 Rate, register and sign off

1. Rate each row: likelihood times impact. 7 to 9 High, 4 to 6 Medium, 1 to 3 Low.
2. Every High row gets a risk register ID and an owner role.
3. Walk the client approver through the boundaries and gaps; record approval with name, role and date on the sign-off page.

CHAPTER 4

Template · Inventory and Threat Rows

SOP-03-ARCHITECTURE-INVENTORY.PS1 · ARCHITECTURE INVENTORY · READ ONLY POWERSHELL

```powershell
<#  SOP-03 template: read-only architecture inventory for a STRIDE workshop. Changes nothing.
    Produces the boundary inputs (networks, peerings, NSG rules, private endpoints, identities, public IPs). #>
param([string]$Out = "./threat-model-inputs-$(Get-Date -Format yyyyMMdd).json", [string]$ResourceGroupLike =
'<product>-*')
$rgs = Get-AzResourceGroup | Where-Object ResourceGroupName -like $ResourceGroupLike
$inv = [ordered]@{}
$inv.VNets    = Get-AzVirtualNetwork | Where-Object ResourceGroupName -in $rgs.ResourceGroupName |
               Select-Object Name, @{n='Space';e={$_.AddressSpace.AddressPrefixes}}, @{n='Subnets';e=
{$_.Subnets.Name}},
                             @{n='Peerings';e={$_.VirtualNetworkPeerings | ForEach-Object { "$($_.Name)-
>$(($_.RemoteVirtualNetwork.Id -split '/')[-1])" }}}
$inv.NsgRules = Get-AzNetworkSecurityGroup | Where-Object ResourceGroupName -in $rgs.ResourceGroupName | ForEach-
Object {
                  $n = $_.Name; $_.SecurityRules | Select-Object @{n='Nsg';e={$n}}, Name, Direction, Access,
Priority, SourceAddressPrefix, DestinationPortRange }
$inv.PublicIPs        = Get-AzPublicIpAddress | Select-Object Name, ResourceGroupName, @{n='AttachedTo';e=
{$_.IpConfiguration.Id -replace '.*/providers/',''}}
$inv.PrivateEndpoints = Get-AzPrivateEndpoint | Select-Object Name, @{n='Target';e=
{($_.PrivateLinkServiceConnections.PrivateLinkServiceId -split '/')[-1]}}
$inv.ManagedIdentities = Get-AzVM | Where-Object ResourceGroupName -in $rgs.ResourceGroupName | ForEach-Object {
                  $id = $_.Identity.PrincipalId
                  [pscustomobject]@{ Vm = $_.Name; Roles = (Get-AzRoleAssignment -ObjectId $id | ForEach-Object {
"$($_.RoleDefinitionName) @ $(($_.Scope -split '/')[-1])" }) } }
$inv | ConvertTo-Json -Depth 6 | Set-Content $Out
Get-FileHash $Out -Algorithm SHA256 | Select-Object Hash, Path     # record the hash with the workshop notes
```

SOP-03-THREAT-MODEL.TEMPLATE.CSV · THREAT MODEL ROWS · SAMPLE BOUNDARIES B1 TO B6 CSV

```csv
Boundary ID,Boundary,From (zone),To (zone),Data crossing,STRIDE,Threat,Existing control (evidence),Gap,Likelihood
(1-3),Impact (1-3),Rating,Risk ID
B1,Internet to gateway,Internet,Hub: gateway subnet,HTTPS requests,S,Spoofed client / credential stuffing on the
sign-in path,WAF rate-limit rule on /api/auth (WAF policy export),WAF in Detection until UAT ends,2,3,High,R-xx
B1,Internet to gateway,Internet,Hub: gateway subnet,HTTPS requests,T,Request tampering / injection,WAF OWASP rule
set (policy export),,2,2,Medium,
B2,Gateway to app VM,Hub: gateway subnet,Spoke: app subnet,HTTP on app port,I,East-west reachability from other
hub workloads,NSG allow only from gateway subnet (NSG export),,1,3,Medium,
B3,App VM to Key Vault,Spoke: app subnet,Spoke: private endpoint,Secrets over TLS,E,Identity over-privileged
(write or manage vault),VM identity holds Key Vault Secrets User only (role export),,1,3,Medium,
B4,App VM to internet egress,Spoke: app subnet,Internet (NAT),HTTPS to integrations,I,Data exfiltration to any
host on 443,NAT gateway + NSG 443 outbound,No FQDN allow-list,2,3,High,
B5,Operator to control plane,Entra ID,Azure Resource Manager,Role and policy writes,R,Untracked guardrail
change,Management group activity log + guardrail alert (alert test log),,1,3,Medium,
B6,Backup to paired region,Spoke: vault,Paired region,VM recovery points,D,Backup deletion by a compromised
admin,Soft delete + immutability (vault export),Immutability not locked,1,3,Medium,
```

CHAPTER 5

Verification and Troubleshooting

5.1 Verify the model

- ☐ Every boundary in the figure has at least one row.
- ☐ Every control names an evidence file that exists and is hashed.
- ☐ Every High row has a risk register ID.
- ☐ The sign-off page is signed.

5.2 Troubleshooting

Symptom	Likely cause and fix
Resource visualizer is empty	The account lacks Reader on the resource group, or the browser blocked the blade. Use the inventory JSON.
Topology shows no peerings	Network Watcher is not enabled in that region, or the hub is in another subscription you cannot read.
Workshop stalls on application questions	Write them down as out of scope with an owner; the infrastructure model does not answer them.

CHAPTER 6

Summary, Glossary and Review

6.1 Chapter summary

- Boundaries come from the deployed tenant, not from code.
- STRIDE is asked at each boundary; one row per real threat.
- Every control points to evidence; every gap is rated and registered.
- The client signs the model.

Check your understanding

1. What makes a place in the design a trust boundary?
2. Which STRIDE letter does a missing activity log fall under?
3. Why does the builder not rate their own work?
4. When must an exposure be reported before the final report?

6.2 Glossary

Trust boundary	A point where data passes between zones with different owners or trust.
STRIDE	Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege.
Risk matrix	Likelihood times impact, with a required response per band.

6.3 Framework references

Framework	Controls
NIST CSF 2.0	ID.RA
NIST SP 800-53 R5	RA-3, SA-8, SA-11
ISO/IEC 27001:2022	A.5.7, A.8.27